

RESEARCH

Open Access



Integrated risk scoring and exploit prediction for cyber-physical power system vulnerabilities

Firdous Kausar^{1*} , Lisette Batiste¹, Asmah Muallem¹ and Sajid Hussain¹

*Correspondence:

Firdous Kausar
firdous.kausar@mmc.edu
¹Department of Computer Science
and Data Science, School of
Applied Computational Sciences,
Meharry Medical College, Nashville,
TN 37208, USA

Abstract

Cyber-Physical Power Systems (CPPS) increasingly inherit cybersecurity vulnerabilities from industrial control components, yet practitioners lack a CPPS-focused dataset and a consistent way to prioritize remediation beyond generic severity scores. This paper presents a cohesive methodology for collecting, enriching, and modeling CPPS-related CVEs to predict their risk and prioritize remediation. We aggregate over 4,030 ICS-relevant CVEs from public sources (2020–2025) and enrich each with CVSS severity, exploitation data (CISA Known Exploited Vulnerabilities, Exploit Prediction Scoring System), and OT/ICS contextual attributes. Based on the dataset, we develop the two-stage learning framework that achieves the following two goals: (i) the provision of a risk score specific to the CPPS and the indication of the priority of the vulnerabilities, and (ii) an estimated likelihood of exploitation, combining structured indicators with features derived from CVE text. These rankings make triage possible by identifying a set of high priority vulnerabilities while reducing the priority of many others, allowing identification of CPPS components with high-risk issues not accounted for by KEV. The analysis of proposed method is shown to yield more informative prioritization than the severity-only baselines by distinguishing between operationally urgent and non-urgent vulnerabilities. The produced risk levels are intended to be interpretable and deployable, serving as a practical decision support tool for CPPS vulnerability management with the understanding that the true label is uncertain.

Keywords Cyber physical power systems, Vulnerability risk, Machine learning, CVSS, EPSS, Risk scoring

Introduction

Electric power infrastructure, as a quintessential cyber-physical system (CPS), has become a focal point for cyberattacks due to its critical role and the potential for physical disruption. Recent reports underscore that industrial control system (ICS) vulnerabilities are prevalent and can have severe consequences: "70% of the vulnerabilities researched were deep within the ICS network, 39% could cause both a loss of view and a loss of control" [9]. The convergence of operational technology (OT) with IT networks has expanded the attack surface in power grids, while threat actors ranging from state-sponsored groups to cybercriminals increasingly target known weaknesses in these

© The Author(s) 2026. **Open Access** This article is licensed under a Creative Commons Attribution-NonCommercial-NoDerivatives 4.0 International License, which permits any non-commercial use, sharing, distribution and reproduction in any medium or format, as long as you give appropriate credit to the original author(s) and the source, provide a link to the Creative Commons licence, and indicate if you modified the licensed material. You do not have permission under this licence to share adapted material derived from this article or parts of it. The images or other third party material in this article are included in the article's Creative Commons licence, unless indicated otherwise in a credit line to the material. If material is not included in the article's Creative Commons licence and your intended use is not permitted by statutory regulation or exceeds the permitted use, you will need to obtain permission directly from the copyright holder. To view a copy of this licence, visit <http://creativecommons.org/licenses/by-nc-nd/4.0/>.

systems. This elevates the urgency for effective cybersecurity risk management tailored to CPS environments.

Modern power grids rely on Industrial Control Systems (ICS) and other cyber-physical components that increasingly face software vulnerabilities. Recent reports highlight a surge in ICS-related CVEs; for example, over 4,400 ICS vulnerabilities were disclosed between 2010 and 2021, with annual counts nearly doubling from 2020 to 2021 [6]. Unlike general IT vulnerabilities, those in ICS environments carry unique risks due to potential physical impacts, yet no comprehensive structured dataset or automated scoring framework exists for these vulnerabilities. Asset owners and defenders typically rely on generic severity metrics like the Common Vulnerability Scoring System (CVSS) or vendor advisories, which measure technical severity but not actual risk [15]. CVSS (v3.x) provides a 0–10 severity score based on a vulnerability's intrinsic traits, but it “is not a measure of risk” and does not account for whether vulnerabilities are being actively exploited or how critical the affected asset is in an operational context [4]. In practice, security teams struggle to prioritize ICS vulnerabilities, many of which score “High” or “Critical” because contextual factors such as exploitability in the wild, asset importance are not captured by CVSS alone.

Recent industry efforts have introduced supplemental risk indicators. The U.S. Cybersecurity and Infrastructure Security Agency (CISA)'s Known Exploited Vulnerabilities (KEV) catalog enumerates vulnerabilities with confirmed exploitation in the wild [8] offering a binary flag of real-world threat activity. Likewise, the Exploit Prediction Scoring System (EPSS) provides a probabilistic score (0 to 1) estimating the likelihood a CVE will be exploited in the next 30 days [11]. Yet EPSS has limitations too, it intentionally excludes prior exploit status to remain predictive [16], which means it often underestimates already exploited vulnerabilities. In fact, a recent empirical study found that “EPSS rarely predicted exploitability...fewer than 20% of CVEs ever exceeded a 50% chance of exploit beforehand,” whereas many CVEs that were later confirmed as exploited had high CVSS scores [14]. This indicates that neither severity nor standalone exploit probability scores are sufficient; a combination of signals is needed. Within industrial cybersecurity research, approaches such as CISA's Stakeholder-Specific Vulnerability Categorization (SSVC) framework have been proposed to incorporate exploitation status, technical impact, and required response into decision trees for critical infrastructure [22]. Additionally, vulnerability analysts leverage threat intelligence and domain knowledge to measure risk.

Prior research has examined machine learning for vulnerability exploit prediction, showing that using diverse features can improve predictions of which CVEs will be exploited [13]. Notably, the EPSS model itself considers features like vulnerability age, vendor, keywords in descriptions, CVSS metrics, and prior exploit code availability. However, these general models may not capture ICS-specific factors. For example, an obscure buffer overflow in a PLC might have low global exploit likelihood but could be highly critical for a specific power utility if that PLC is widespread in substations. This gap motivates an integrated approach that blends general-purpose scores (CVSS, EPSS) with CPS domain context to produce a tailored risk assessment for power system vulnerabilities. Furthermore, existing datasets like ICS-LTU2022 [3] have begun compiling ICS vulnerabilities from advisories, but focus on categorization and trends rather than providing a unified, enriched dataset for predictive modeling. To the best of our knowledge,

no prior work has combined vulnerability data, exploitation data, and power-system context into a machine learning model for risk prioritization. This gap leaves critical infrastructure operators without data-driven guidance on which of the many “severe” CVEs merit urgent attention.

While previous research initiatives related to vulnerability management in CPPS/ICS were mostly based on general vulnerability scores (e.g., CVSS scores), general threat assessments, or vulnerability lists, it has three shortcomings from an applied level: (i) it fails to provide an environment-specific, machine-readable data set that assigns CVE information into an operational context related to assets; (ii) it fails to offer an integrated data-based signal for CVSS-driven vulnerability scoring that incorporates exploitation information with an operational context for prioritization; (iii) it fails to assess exploit likelihood prediction that preserves its performance against limited “known exploited” information. In this paper, these challenges will be addressed where an enhanced data set for CVE information related to CPPS will be developed based on an integrated prediction method related to two steps for continuous scoring and prediction.

The contributions of our work are as follows: (1) Data: a curated dataset of thousands of CPPS vulnerabilities enriched with threat intelligence and contextual factors, which can be a foundation for future research. (2) Methodology: an integrated pipeline for vulnerability data collection, enrichment, and machine learning modeling tailored to cyber-physical power systems. (3) Risk model: a risk scoring mechanism that combines CVSS severity with real-world exploitation signals (EPSS, KEV) and the environment context, improving prioritization over severity-only ranking. (4) Analysis: insights from the application of the model and identification of the top risk vulnerabilities and affected products in our dataset. We also provide SHAP-based explanations for the risk regression component to quantify which inputs most influence prioritization scores and to support analyst trust and auditability. The complete data set and implementation code are available at: GitHub [10] to support reproducibility and future research.

The rest of this paper is organized as follows: Section II reviews related work on vulnerability scoring and ICS security datasets. Section III describes our methodology, including data collection, enrichment, and the machine learning models and risk scoring approach. Section IV presents results and analysis characteristics of the CPPS CVE dataset, model performance metrics, example outputs, and an explanation of key features. Section V concludes with implications for the cybersecurity of the power system and future directions.

Related work

Prior work on smart grid and CPPS security has largely focused on vulnerability testing and threat modeling using established frameworks. Surveys of smart-grid vulnerability testing report techniques such as penetration testing, static/dynamic analysis, and simulation, and note that severity measures like CVSS are commonly used to prioritize threats [5]. For example, Banik *et al.* observed that CVSS-based severity scores helped to assess false-data-injection attacks on grid measurement systems [5]. Other approaches use qualitative threat models: Abdul Rahim *et al.* adapted the STRIDE/DREAD framework to classify and rank threats in a solar-PV-enabled grid, identifying high-risk events such as information disclosure and tampering [1]. In the IoT/ICS context, specialized scanning tools have been developed. Zhang *et al.* describe a passive vulnerability

detection system for power-IoT devices, matching device fingerprints to the NVD to identify known vulnerabilities [24]. While such tools can enumerate software flaws in grid assets, they do not synthesize the data into a unified vulnerability risk dataset.

General vulnerability repositories (e.g., NVD) exist, but few curated datasets focus on cyber-physical power systems. Nikolaou *et al.* compiled a set of 250 vulnerabilities specifically relevant to energy-sector critical infrastructure, mapping each vulnerability to asset types and scoring them with CVSS [18]. Their framework enriches each CVE entry with contextual threat intelligence in STIX format, enabling correlation analysis [18]. In the industrial control domain, Alanazi *et al.* introduced the ICS-LTU2022 dataset, containing biannual vulnerability records for ICS components. This dataset includes rich metadata (e.g., affected products, CISA KEV tags, and textual fields) with “multiple features that can be used for vulnerability assessment and risk evaluation in industrial control systems” [3]. These works highlight the need for domain-specific vulnerability databases. Our work similarly collects CPPS-relevant CVEs (over 4,000 entries) and enriches them with threat-intelligence feeds and contextual factors (e.g., asset criticality), bridging the gap left by prior datasets.

Machine learning has been applied to smart-grid security, but mostly for anomaly/intrusion detection rather than vulnerability scoring. Paul *et al.* review numerous ML approaches (SVMs, neural networks, etc.) for detecting data anomalies and false-data-injection attacks in smart grids [19]. Such methods focus on real-time detection, not on pre-attack vulnerability risk. To our knowledge, no prior CPPS work has implemented an end-to-end ML pipeline that ingests vulnerability records and predicts risk scores. While the ICS-LTU authors mention potential ML use, they do not report a model implementation [3]. In contrast, our pipeline automates CPPS CVE collection, enrichment, and modeling to estimate composite risk scores and exploit probabilities. Unlike prior static assessments, our model incorporates historical exploit data and threat intelligence.

Most existing CPPS risk models rely on CVSS severity scores, often combined with network analyses. Yan *et al.* propose a dynamic risk assessment method using CVSS base metrics and time-aware attacker capabilities to predict exploitation probability [23]. Gao *et al.* propose a DER-focused framework combining vulnerability likelihood and criticality into a Bayesian attack-probability model [12]. In both cases, exploitability is estimated through normalized CVSS subscores. Mitikiri *et al.* use CVSS thresholds to trigger network reconfiguration in distribution systems for resilience under cyber attacks [17]. While valuable, these approaches lack integration of live exploitation data. Our work advances this by blending CVSS with Exploit Prediction Scoring System (EPSS) values and CISA’s Known Exploited Vulnerabilities (KEV) indicators to compute a hybrid risk score grounded in real-world conditions.

Formulation of risk prioritization can also be conceptualized as the problem of multi-criteria decision-making, where different pieces of information are combined to achieve the process of ranking. Recent studies in other related domains have explored the integration of machine learning techniques and the process of multi-criteria decision-making to improve rankings and interpretation, including ensemble learning in conjunction with the Analytic Hierarchy Process (AHP) for evaluation of energy performance, and ML+MCDM approaches that model the process of building risk-related feature values to aid ranking in decisions [20] [21].

Existing CPPS approaches emphasize either qualitative threat models (e.g., STRIDE/DREAD [1]), static scoring (CVSS only [17, 23]), or asset fingerprinting tools [24]. They lack a unified vulnerability dataset, ML-based scoring, and explainability. Our work uniquely integrates all these dimensions, including SHAP-driven explainability, which has not been previously applied in CPPS risk modeling.

Proposed method

Our methodology integrates heterogeneous data sources and employs a two-pronged modeling approach (regression and classification) to produce an enriched risk score and exploit prediction for each vulnerability. The major components of the approach are: data collection and enrichment, feature engineering, model training with time-based validation, and probability calibration. The overall goal is to mimic how an analyst might combine vulnerability attributes with threat intelligence to assess risk, but automate and quantify this process using machine learning.

Data collection and enrichment

We constructed a dataset of vulnerabilities relevant to the electric power domain, drawing on both public vulnerability databases and ICS-specific advisories. The primary sources include:

- **NVD CVE records:** For each CVE, we obtained the CVSS v3.1 base score and attributes like Attack Vector, Attack Complexity, Privileges Required, User Interaction, impact on CIA triad, etc., and the textual description. The CVSS base score serves as a baseline severity metric, and the vector is parsed into individual features..
- **EPSS scores:** We incorporated Exploit Prediction Scoring System [11] data by retrieving the EPSS probability for each CVE. This numeric feature (0 to 1) represents the model-estimated likelihood of exploitation within 30 days of the score's date [16]. EPSS serves as an informative prior from a global perspective.
- **CISA known exploited vulnerabilities (KEV):** We cross-referenced each CVE against CISA's KEV catalog up to the latest available date in our study [8]. A binary feature is `_KEV` is set to 1 for vulnerabilities listed as known exploited. These entries also guide our ground truth for training the exploit prediction classifier. We treat *KEV* inclusion as an indication that the CVE has been exploited in the wild. While *KEV* is not comprehensive or real-time, it provides high-confidence labels for model learning.
- **ICS-CERT advisories:** We collected ICS advisories related to power sector products [7]. These advisories often group multiple CVEs affecting a product and provide additional context such as the vendor, equipment or software name, version ranges, a summary of the issue, and sometimes custom severity or exploitability ratings. We parsed advisories to create an enrichment table by CVE: including fields like vendor, product names, and the advisory description text. We also noted if the advisory mentions known exploits or incidents.

We developed a pipeline to aggregate and enrich CPPS-related vulnerability data. As described earlier, we collected CVEs from public sources such as NVD feeds for year 2020 to 2025 and ICS-CERT advisories by filtering for relevant vendors and keywords.

This yielded a base set of 4,030 CVEs (for year 2020–2025) related to cyber-physical power systems. We then enriched each CVE with a variety of features. Table 1 summarizes the features extracted and engineered through the multi-stage pipeline. Each CVE record combines severity, exploit likelihood, asset criticality, and text-derived contextual features, yielding a comprehensive representation suitable for predictive risk modeling.

Feature engineering

All the above data was transformed into a set of features suitable for machine learning. We construct three sets of features: (i) numeric features for severity, exploitability, temporal, and context signal; (ii) categorical attributes for vendor, product, and asset; and (iii) text-based features for vulnerability descriptions (TF-IDF features and keywords). Table 2 lists the final set of features used by the regressor and the exploitation classifier. This feature set allows models to consider both the classic vulnerability properties and contextual factors in combination.

Risk modeling and prioritization

We compute a continuous risk score per vulnerability as

$$\text{Risk} = L_{\text{score}} \times I \times (1 + \alpha E), \quad \alpha \in [0, 1], \quad \alpha \approx 0.3,$$

Table 1 Summary of Enrichment Features and Derived Attributes in the CPPS Vulnerability Dataset

Feature category	Attributes	Source or method	Description
Base Identification	CVE_ID, Vendor, Product, Year	NVD JSON feeds (2020–2025), ICS-CERT advisories	Unique identifiers, restricted to CPPS-related vendors/products ($\approx 4,030$ CVEs)
Severity Metrics	CVSS_v3_BaseScore, CVSS_v3_Vector, fallback CVSS_v2_Score	NVD CVSS data	Quantify technical severity (v3 coverage >97%; defaults used where missing)
Asset Mapping & Criticality	Asset_Type (e.g., PLC, HMI, network device), Criticality (0–1)	Vendor–product mapping table	Represent functional role and operational importance within the power grid
Threat Intelligence	is_KEV, EPSS_Score, EPSS_Percentile	CISA KEV Catalog; EPSS API	Measure likelihood of exploitation; KEV indicates known exploitation. EPSS/KEV are used for labeling/validation and risk modeling; excluded from exploit-classifier inputs in leakage-controlled experiments
Temporal Features	Published_Date, Age_Days	Derived from NVD metadata	Capture vulnerability age as a proxy for exploit opportunity
Derived Binary Flags	is_remote, is_priv_none, base_flags (AV:N, AC:L, PR:N, UI:N count)	Parsed from CVSS vectors	Summarize favorable exploit conditions (network-accessible, low complexity, etc.)
Data Quality Handling	Missing numeric $\rightarrow 0$; missing text $\rightarrow$ “unknown”	Preprocessing step	Ensure completeness and consistency; handle absent EPSS/text
Textual Indicators	TF-IDF (unigrams/bigrams, top 4,000)	Cleaned CVE descriptions $\rightarrow$ TF-IDF	Capture linguistic patterns linked to exploitability (e.g., “unauthenticated”, “remote code execution”)
Exposure & Environment	Exposure_0_5, Criticality_0_5	Asset-level mapping and scaling	Weight each vulnerability by contextual exposure within CPPS
Categorical Encodings	One-hot encoded vendor/product categories	Derived from Vendor/Product fields	Enable model interpretability by grouping similar technologies
Final Dataset Composition	$\sim 50+$ features per CVE	Aggregated via pipeline (Stages 1–4)	Unified table (combined_unified.csv) for downstream ML and risk modeling

Table 2 Feature groups for risk regression and exploit classification

Group	Risk regression features (examples)	Exploit classification features (examples)
Numeric	CVSS base score; CVSS exploitability subscore (normalized); EPSS score/percentile; Age (days, log-scaled); reference count; CWE count; criticality (0–1); exposure (0–1)	CVSS base score; CVSS exploitability subscore (normalized); Age (days, log-scaled); reference count; CWE count; criticality (0–1); exposure (0–1); derived binary flags from CVSS (e.g., AV/AC/PR/UI indicators)
Categorical	Vendor (top-N one-hot + Other); product family (top-N one-hot + Other); asset type (PLC/RTU/IED, HMI/SCADA, network device); CWE category; key CVSS vector fields (AV, AC, PR, UI)	Vendor (top-N one-hot + Other); product family (top-N one-hot + Other); asset type (PLC/RTU/IED, HMI/SCADA, network device); CWE category; key CVSS vector fields (AV, AC, PR, UI)
Text-derived	TF-IDF features from CVE/advisory descriptions (uni/bi-grams, top-K terms); keyword indicators (e.g., “unauthenticated”, “remote code execution”, “bypass”, “deserialization”)	TF-IDF features from CVE/advisory descriptions (uni/bi-grams, top-K terms); keyword indicators (e.g., “unauthenticated”, “remote code execution”, “bypass”, “deserialization”)

To prevent target leakage, EPSS and KEV inclusion are excluded from exploit-classifier inputs whenever they are used in label construction

where L_{score} is an analytic likelihood component used for score construction, I is impact, and E is an environmental modifier that can increase risk slightly. We distinguish L_{score} from the learned exploit probability p_{exploit} produced by the leakage-controlled exploit classifier in Section X.

Likelihood $L_{\text{score}} \in [0, 1]$. We combine exploit-pressure signals and cap the result at 1:

$$L = \begin{cases} 1, & \text{if CVE is in CISA KEV} \\ \min(w_1 \text{CVSS}_{\text{norm}} + w_2 \text{EPSS}_{\text{norm}} + w_3 1_{\{AV:N \wedge AC:L\}}, 1), & \text{otherwise.} \end{cases}$$

with $w_1, w_2, w_3 \geq 0$ and $w_1 + w_2 + w_3 \leq 1$.

- $\text{CVSS}_{\text{norm}}$ is the CVSS *exploitability* subscore scaled to $[0, 1]$ by dividing by its maximum.
- $\text{EPSS}_{\text{norm}}$ is the EPSS value or percentile scaled to $[0, 1]$. If EPSS is missing, use a floor $\text{EPSS}_{\text{norm}} = L_{\text{floor}}$ (e.g., 0.1) rather than zero.
- $1_{\{AV:N \wedge AC:L\}}$ adds a boost for network-accessible, low-complexity vectors. *Impact* $I \in [0, 1]$.

Impact reflects the consequence on the system if exploited. We define

$$I = \text{criticality} \times \text{exposure},$$

where criticality, exposure $\in [0, 1]$. Higher values correspond to more important and more accessible assets. We emphasize that *criticality* and *exposure* are proxy context indicators derived from public asset-type mappings and heuristic exposure cues, not utility-specific topology or operational ground truth.

Environmental modifier $E \in [0, 1]$. E captures site-specific or operational amplifiers (for example, harsh conditions or critical operating contexts). It is bounded so that it *never decreases* risk:

$$1 \leq 1 + \alpha E \leq 1 + \alpha.$$

Calibration. Parameters $w_1, w_2, w_3, \beta_1, \beta_2, \alpha$ and L_{floor} are set based on domain guidance and sensitivity analysis over plausible ranges. We report the chosen values and evaluate robustness of tier assignments under small threshold/weight perturbations.

Interpretation. The score is real-valued in $[0, 1 + \alpha]$ before optional rescaling/clipping. In our dataset, the observed risk values fall within $[0.167, 0.827]$, so no additional rescaling was required. High L_{score} with high I yields scores near the top of the range, while low values on either dimension suppress the score. The environmental term adjusts risk upward in especially critical contexts without overwhelming the primary $L_{\text{score}} \times I$ signal.

As shown in Table 3, vulnerabilities are categorized into four tiers—Act Now, High, Medium, and Low—based on their risk scores and recommended response times.

Escalation rule: any KEV-listed CVE is *Act Now* regardless of score. *Quantile alternative:* top 5% = Act Now, next 15% = High. *Overrides:* mission-critical assets may be bumped up one tier.

This scheme concentrates effort on vulnerabilities that actually endanger operations. It also avoids noise: most CVEs are never exploited, so KEV-based escalation and calibrated thresholds prevent false urgency.

Exploit likelihood classifier

In parallel, we train a classifier to estimate the likelihood that a given CVE will be exploited in the wild (or leveraged in malware campaigns). Because exploitation is only partially observable at scale, we use a weakly supervised labeling strategy grounded in external evidence. In our combined label construction, a CVE is labeled positive if it appears in the CISA Known Exploited Vulnerabilities (KEV) catalog or if its EPSS score exceeds a high-risk threshold (e.g., $\text{EPSS} \geq 0.90$); all remaining CVEs are treated as negative for training and evaluation. To prevent target leakage, any signal used to construct exploit labels (i.e., KEV membership and EPSS) is explicitly excluded from the exploit-classifier input feature set. The classifier therefore learns from severity and attack-surface characteristics (CVSS components and derived flags), temporal features (e.g., vulnerability age), vendor/product and asset-type indicators, and text-derived features from CVE/advisory descriptions. Because the data are imbalanced, we apply class weighting and report precision–recall metrics with bootstrap confidence intervals. Finally, we calibrate the classifier outputs (Platt scaling or isotonic regression) to produce a probabilistic score p_{exploit} .

Priority score. We combine the regression- and classification-based signals as

$$\text{Priority} = \max\{\text{predicted_risk}, p_{\text{exploit}} \times \text{Criticality} \times \text{Exposure}\}.$$

This promotes items that are either intrinsically high risk under the constructed risk model or have elevated exploit likelihood on critical, exposed assets. We then rank CVEs by Priority and report results using tiered cutoffs (e.g., fixed thresholds or

Table 3 Risk priority tiers, actions, and fixed thresholds

Tier	Action guidance	Fixed threshold
Act Now	Immediate mitigation. Includes any KEV-listed CVE and any item above the critical risk threshold	≥ 0.80
High	Substantial risk; schedule remediation in the near term	$[0.60, 0.79]$
Medium	Meaningful risk; address in the normal patch cycle	$[0.30, 0.59]$
Low	Minimal risk; defer or monitor	< 0.30

distribution-based quantiles) to support operational triage (e.g., top 10% = Extreme, next 20% = High, next 20% = Medium, bottom 50% = Low).

Model training and selection

We experimented with multiple algorithms for the risk regression and the exploit classifier. For the risk score, we treated our formula-based `Risk_base` as a target and trained regressors to see whether machine learning could better calibrate or adjust it. We tried linear models (Ridge regression) and ensemble trees (XGBoost, Random Forest). For the exploitability classification, we tried tree ensembles, Random Forest, and Logistic Regression.

Our predictive modeling approach consists of two components working in tandem: a regression model to predict the continuous risk score (logit-risk), and a classification model to predict the binary outcome of exploitation (Yes/No). The regression gives a fine-grained estimate of exploit likelihood for each vulnerability, and the classifier focuses on distinguishing truly exploited vs. non-exploited cases. In practice, the regression output can be used directly to rank vulnerabilities by risk, while the classifier can provide calibrated probabilities and help flag a subset as "likely exploited." We evaluated multiple algorithms for each component and even mixed different algorithms for regression vs. classification to find the best combination. Regression models evaluated include:

- **Ridge regression:** a linear model with L2 regularization. We expected that after the logit transformation, a linear combination of features might predict risk very well, especially given strong signals like EPSS and CVSS. Ridge can handle the high-dimensional feature space by shrinking lesser features' coefficients, reducing overfitting.
- **Random forest regressor:** an ensemble of decision trees that can capture non-linear interactions. RF is robust to outliers and can naturally model some interactions between features. However, with many sparse features, the forest might split on a lot of noise, so we included it to compare as a non-linear baseline.
- **Extreme gradient boosting (XGBoost) regressor:** a boosted tree model known for often achieving high predictive accuracy. XGBoost can capture complex non-linear patterns and interactions among features, which might be beneficial if risk is a complicated function of the inputs. We tuned XGBoost with a modest tree depth to avoid overfitting, and early stopping to find an optimal number of trees.
- **Histogram gradient boosting regressor:** an efficient implementation of gradient boosting that bins continuous features and can be faster on large datasets. We included this as it often performs comparably to XGBoost with less parameter tuning.

Classification models evaluated include:

- **Logistic regression:** a simple linear classifier to predict exploitation from the features or possibly from the regression output. This serves as a baseline for classification. Logistic regression will treat the problem as linearly separable in feature space; given the complexity of exploit prediction, we anticipated it might underperform if non-linear signals are important.

- **Random forest classifier:** using an ensemble of trees to classify exploited vs not. RF can capture non-linear relations and is fairly robust, though it may output less calibrated probabilities without additional calibration.
- **XGBoost classifier:** the boosted tree classifier counterpart to the regressor. We expected XGBoost to likely yield high precision-recall performance in identifying the exploited cases, by combining multiple weak signals.
- **Histogram gradient boosting classifier:** similar to above but using the histogram-based boosting. This classifier often handles categorical and continuous features well and can provide well-calibrated probability estimates if properly tuned.

Result and analysis

We applied the above methodology to our CPPS vulnerability dataset and obtained both quantitative model performance results and qualitative insights. In this section, we first describe the characteristics of the collected dataset and enrichment (addressing the novelty of the data itself), then present the model evaluation metrics, and finally discuss the outputs: the prioritized vulnerabilities, risk distribution, and feature importance interpretations.

CPPS vulnerability dataset insights

Exploit occurrence by vendor

Out of the 4,030 CPPS-related CVEs in our dataset, only 18 (0.45%) are present in CISA's KEV catalog. These exploited cases are not evenly distributed across vendors. In fact, we found that the majority of the known-exploited CPPS CVEs come from just a few vendors. Figure 1 illustrates the distribution of known exploited vulnerabilities by vendor within our CPPS CVE subset. Citrix accounts for the largest share of exploited CVEs, reflecting the prevalence of attacks on remote access infrastructure used in OT networks. Specifically, out of the 18 KEV-tagged CPPS CVEs, a significant portion were Citrix ADC/Gateway vulnerabilities. Other notable vendors with exploited CVEs include AMI, Northgrid, Barracuda, arrayNetworks, Mitel, VMware, Siemens, Ivanti, Facade, and Palo Alto Networks, each of which has at least one known-exploited CVE in our dataset. This highlights that many exploited vulnerabilities in OT environments are actually in enterprise/edge components that bridge IT and OT rather than in the PLCs or relays themselves.

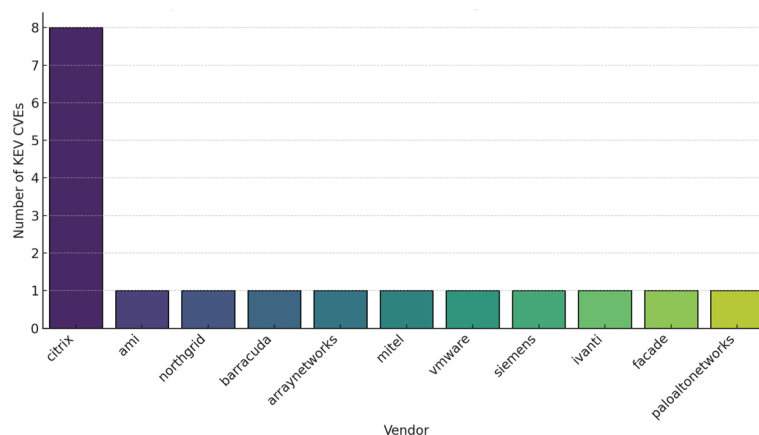


Fig. 1 Known Exploited Vulnerabilities (CISA KEV) by Vendor in CPPS CVE Subset

Vulnerability volume by vendor

We also examined the overall concentration of vulnerabilities by vendor. A few vendors account for a large portion of the CPPS vulnerabilities. Notably, Siemens products make up about 27% of the dataset (over 1,100 CVEs), far more than any other vendor. Figure 2 shows the top vendors: Siemens, Schneider Electric (425 CVEs), Rockwell Automation (148), Moxa (109), and ABB (108) are the top five, together representing nearly half of all CVEs. This is unsurprising given these companies' broad portfolios in the power domain. It underlines the importance of focusing security efforts on major equipment suppliers. However, quantity doesn't directly equal risk. Siemens has many CVEs, but not all are high risk (many are moderate issues in less critical devices), whereas a vendor with fewer CVEs could have one particularly critical flaw. Our risk model takes volume into account only indirectly e.g., if a vendor has many exploits, the model might learn that as a subtle feature correlation, but it does not automatically assume a CVE is risky just because it comes from a dominant vendor.

Asset mapping and data quality

We successfully obtained CVSS v3 scores for 97.4% of the CVEs which is excellent coverage for severity analysis and prioritization. EPSS scores were available for roughly 80% of the CVEs, some recent ones or very OT-specific ones weren't in EPSS feeds. The KEV flag, of course, is extremely sparse as only 18 positives. For asset mapping, we categorized all CVEs into asset types; the most common categories were HMI/SCADA software (30% of CVEs), PLC/RTU/IED firmware (~12%), and networking/communication devices (~4%), with the remainder classified as miscellaneous or other ICS devices. We assigned criticality ratings accordingly; for example, protective relays and control centers were rated as high criticality, whereas engineering workstations were assigned slightly lower criticality. An additional observation during data roll-up was that some CVEs not truly related to Cyber-Physical Power Systems (CPPS) had been pulled into the dataset due to keyword matches. For instance, a project titled "*School Dormitory Management System*" had a high CVE count and was initially tagged as SCADA solely because of the generic term "*management system*." We filtered out such obvious false positives during curation. This process highlights the difficulty of building an ICS-specific dataset; future work could further reduce noise by cross-verifying each entry against authoritative ICS advisory sources (e.g., CISA ICSA bulletins and vendor advisories).

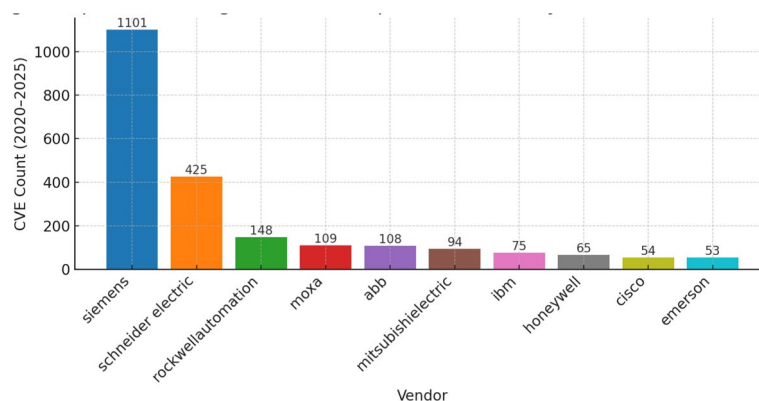


Fig. 2 Top CPPS vendors by number of CVEs (2020-2025)

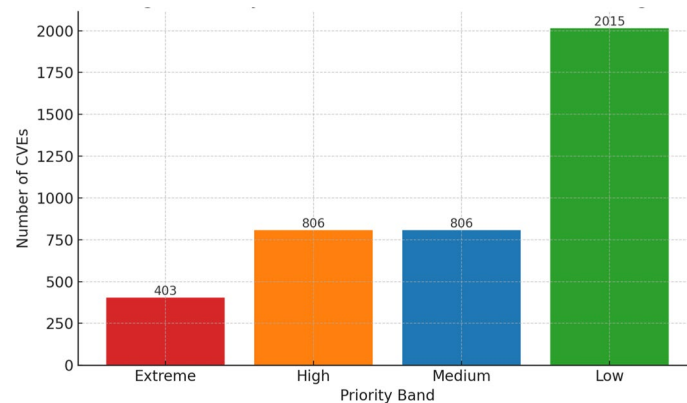


Fig. 3 Priority distribution of CPPS CVEs after scoring

Table 4 Top 10 CPPS CVEs in CISA's KEV catalog (known-exploited), ranked by risk score

CVE ID	Vendor	Product	CVSS	Risk	Priority
CVE-2021-44228	Siemens	6BK1602 0AA12 OTP0 (Firmware)	10.0	0.685	Extreme
CVE-2023-28461	Array Networks	ArrayOS AG	9.8	0.605	Extreme
CVE-2021-3129	Facade	Ignition (Software)	9.8	0.605	Extreme
CVE-2021-22893	Ivanti	Connect Secure (Software)	10.0	0.605	Extreme
CVE-2022-22947	VMware	Spring Cloud Gateway	10.0	0.605	Extreme
CVE-2023-2868	Barracuda	Email Security Gateway 300 (Firmware)	9.8	0.605	Extreme
CVE-2020-2021	Palo Alto Networks	PAN-OS	10.0	0.604	Extreme
CVE-2023-6548	Citrix	NetScaler ADC	8.8	0.572	High
CVE-2025-6543	Citrix	NetScaler ADC	9.8	0.571	High
CVE-2023-4966	Citrix	NetScaler ADC	7.5	0.540	High

Prioritized vulnerabilities and risk distribution

After scoring all CVEs, we produced a ranked list and categorized each vulnerability into priority levels. By construction, we designated the top ~10% of CVEs as Extreme risk, the next 20% as High, the next 20% as Medium, and the bottom ~50% as Low priority using the priority score described in Section 3. The distribution of priority categories for all 4,030 CPPS CVEs is as follows: Extreme – 403 CVEs (10%); High – 806 (20%); Medium – 806 (20%); Low – 2,015 (50%). This stratification is deliberate, but it is still informative to examine which CVEs fall into *Extreme* versus *Low*. Figure 3 visualizes the count of CVEs in each priority category. Approximately half of the CPPS CVEs are labeled Low priority; these tend to be vulnerabilities with low exploitability on lower-criticality devices. At the other end, the top 10% labeled Extreme include many network-facing, high-severity issues on critical systems. As expected, the majority of vulnerabilities end up in lower tiers, but a significant minority (the top 30% comprising Extreme+High) warrant close attention. These results can guide asset owners to focus their mitigation efforts. We next examine which vulnerabilities and products are most prominent in the top categories.

Table 4 lists a sample of the top 10 CPPS-related CVEs that appear in CISA's KEV catalog. Many of these, such as CVE-2021-44228 (Log4Shell, affecting software used by Siemens) and CVE-2022-22947 (Spring4Shell in VMware software used in OT environments) are well-known critical exploits [2]. Interestingly, one of the KEV-listed CVEs is a 2025 vulnerability in Citrix ADC, showing that even newly disclosed issues can quickly be added to KEV if exploited. We include this table to illustrate the gap in existing

industry practices: even these critical, exploited vulnerabilities had to be found by manually cross-referencing the KEV list with ICS product lists - our dataset and pipeline automate such correlation. Not all KEVs received an Extreme priority in our model; if a KEV was on a less critical asset, our model might rate it as High. However, the presence of the KEV flag generally pushed them towards the top of the list in our risk scoring.

Our model's top 10 highest risk CVEs, categorized as Extreme, are not limited to those with known exploits. Table 5 shows the Top 10 highest-risk CVEs as ranked by our system, none of these had been seen in KEV at the time of analysis, yet our model predicts them to be exceptionally risky. All of them fell into the Extreme priority category. We list their key contributing factors ("explanation") and risk scores. A clear pattern emerges: most have AV:N + AC:L in their CVSS base (network attack vector and low complexity), meaning they are remotely exploitable with little effort, essentially "wormable." Many also have HighCriticality, 8 out of 10 are vulnerabilities in devices or software from ABB or GE used in substations such as protection relays or historian servers, which we rated as high criticality to grid operations. None of these top 10 were in KEV to our knowledge, which is exactly where a predictive model shows its value. In other words, the model has surfaced several less-publicized vulnerabilities that have a similar risk profile to notorious exploits, even though they have not yet been reported as exploited.

Next, we aggregated the results by product to see which systems pose the greatest risk overall. Table 6 shows a subset of the product-level risk rollup. For each product, we looked at the maximum PriorityScore among its CVEs, the average, and how many High/Extreme vulns it has. We list the top 8 products by max risk.

Figure 4 shows the distribution of the initial risk scores for all CVEs in our dataset. Most vulnerabilities have relatively low raw risk, with a long tail of higher-risk cases. This distribution reflects that truly high-probability exploits are rare, which is expected, as only a small fraction of vulnerabilities ever see exploitation in the wild.

Experimental setup and evaluation framework

Each model was trained on a training set of 3,224 CVEs and tested on a hold-out set of 806 CVEs. We used a time-based split: the training data consisted of older vulnerabilities, and the test data consisted of the most recent CVEs by publication date. This

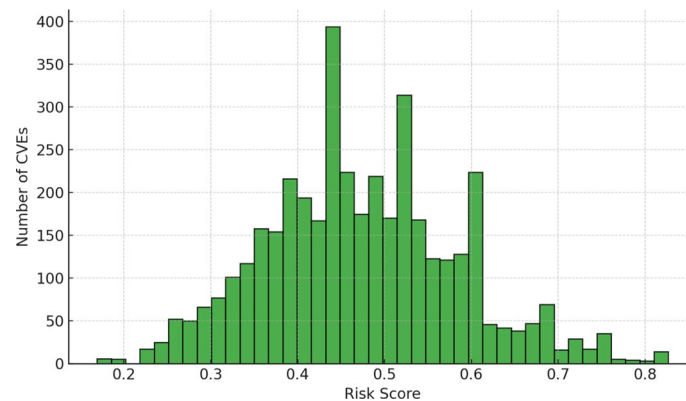
Table 5 Top 10 highest-risk CPPS CVEs predicted by our model that were *not* in CISA's KEV at analysis time

CVE ID	Vendor	Product	Risk	Explanation
CVE-2024-6298	Abb	Aspect Ent 12 Firmware	0.827	AV:N+AC:L, HighEPSS, HighCriticality, NotInKEV
CVE-2021-40521	Airangel	HSMX App 25 Firmware	0.820	AV:N+AC:L, HighEPSS, HighCriticality, NotInKEV
CVE-2024-48845	Abb	Aspect Ent 2 Firmware	0.800	AV:N+AC:L, HighCriticality, NotInKEV
CVE-2024-51550	Abb	Aspect Ent 12 Firmware	0.797	AV:N+AC:L, HighCriticality, NotInKEV
CVE-2024-48840	Abb	Aspect Ent 2 Firmware	0.795	AV:N+AC:L, HighCriticality, NotInKEV
CVE-2024-48839	Abb	Aspect Ent 2 Firmware	0.793	AV:N+AC:L, HighCriticality, NotInKEV
CVE-2023-0755	GE	Digital Industrial Gateway Server	0.788	AV:N+AC:L, HighCriticality, NotInKEV
CVE-2020-24679	Abb	Symphony + Historian	0.763	AV:N+AC:L, HighCriticality, NotInKEV
CVE-2021-37749	Hexagon Geospatial	GeoMedia WebMap	0.758	AV:N+AC:L, HighCriticality, NotInKEV
CVE-2020-12017	GE	RT430 Firmware	0.756	AV:N+AC:L, HighCriticality, NotInKEV

All have CVSS≈9.8 and are marked Extreme

Table 6 Highest-risk CPPS products (vendor/product rollout), ranked by aggregated risk

Vendor	Product	Asset type	Risk
ABB	Aspect Ent 12 (all firmware)	Protection Relay	0.827
Airangel	HSMX App 25 (firmware)	SCADA Server	0.820
ABB	Aspect Ent 2 (all firmware)	Protection Relay	0.800
GE	Digital Industrial Gateway (all)	SCADA Server	0.788
ABB	Symphony+ Historian (all versions)	Protection Relay	0.763
Hexagon	GeoMedia WebMap (all versions)	SCADA Server	0.758
GE	RT430 (Firmware)	SCADA Server	0.756
School Dormitory Mgmt Sys.	Dormitory System	SCADA Server	0.756
ABB	800xA System	Protection Relay	0.749
Siemens	SIPROTEC 5 (Variant CP050)	Protection Relay	0.748

**Fig. 4** Distribution of Initial CVE Risk Score

simulates the real-world scenario of predicting risk for new vulnerabilities using a model trained on past data, and avoids temporal leakage. Notably, a dummy baseline model that predicts the average logit-risk for all instances yields an R^2 of 0.00 on the test set, confirming that the problem is non-trivial and that our models must learn actual signals to outperform random guessing. For classification, the baseline would correspond to a very low Precision-Recall AUC and a Brier score reflecting the prevalence. To partially address temporal generalization, we additionally report a non-circular KEV-only evaluation on the held-out window, quantifying workload required to capture later KEV-confirmed CVEs under multiple baselines (Sec.4.8).

We implement the independent regression-classification evaluation framework. Our regression and classification targets are closely related, we use the same features for both and train separate models. We evaluated each combination of regressor + classifier as an independent pipeline to see which pairing yields the best overall results. We emphasize calibration and discrimination in evaluation: calibration refers to how well the predicted probabilities match actual outcomes, and discrimination refers to how well the model can rank true positives above negatives.

Model performance overview

Evaluation uses a strict time-based split (train on earlier disclosure dates; test on later dates) to assess forward-looking generalization. After training and testing, we compiled model performance across four regressors and four exploit classifiers using a time-based split (trained on 3,224 CVEs and tested on 806 CVEs). Table 7 reports regression

Table 7 Risk regression performance on the time-based split (train: 3,224 CVEs; test: 806 CVEs)

Regressor	R^2	MAE
Ridge (Linear)	0.910	0.0222
XGBoost (Trees)	0.903	0.0185
HistGBM (Boosted)	0.886	0.0196
Random Forest	0.854	0.0238

Boldface highlights the best result among the compared models for each evaluation metric (maximum R^2 and minimum MAE)

Table 8 Leakage-aware exploit classification performance under the *combined* label strategy

Classifier	PR-AUC	PR-AUC (95% CI)	Brier
Random Forest	0.378	[0.285, 0.546]	0.0462
XGBoost	0.331	[0.246, 0.496]	0.0460
HistGBM	0.316	[0.241, 0.455]	0.0477
Logistic Regression	0.091	[0.068, 0.129]	0.0580

Boldface highlights the best result among the compared models for each evaluation metric (maximum PR-AUC and minimum Brier)

performance for predicting the constructed continuous risk score using R^2 and MAE, while Table 8 reports exploit classification performance using PR-AUC (with 95% bootstrap confidence intervals) and the Brier score for probabilistic calibration. A higher R^2 indicates closer agreement with the constructed risk score, whereas higher PR-AUC indicates better ranking of positive (weakly supervised) exploited cases in a highly imbalanced setting. Lower Brier scores indicate better-calibrated probabilities.

To address concerns of target leakage in exploit prediction, we adopt a leakage-aware feature protocol: any signals used in exploit-label construction (EPSS and KEV membership) are excluded from the exploit-classifier input features (Table 2). Under the combined weak-supervision strategy (positives: KEV-listed or EPSS above a high-risk threshold), exploit prediction becomes substantially more challenging than in earlier near-ceiling runs, yielding moderate but more realistic performance. As shown in Table 8, the Random Forest classifier achieves the highest PR-AUC (0.378, 95% CI [0.285, 0.546]), while XGBoost attains the best calibration (lowest Brier score, 0.0460). HistGBM performs comparably (PR-AUC 0.316, 95% CI [0.241, 0.455]). Logistic Regression performs poorly (PR-AUC $\approx$ 0.091), suggesting that the leakage-aware exploit signal depends on non-linear interactions among textual, categorical, and CVSS-derived indicators that linear decision boundaries fail to capture.

For risk-score regression, Table 7 shows consistently strong agreement across models, with Ridge achieving the highest R^2 (0.910) and XGBoost yielding the lowest MAE (0.0185). We interpret these results primarily as faithful reconstruction of the analytic risk formulation rather than prediction of an independent ground-truth outcome, since the target score is constructed from structured severity and threat-intelligence components. Taken together, the results support a two-signal prioritization strategy: regression provides a stable, interpretable estimate of the constructed risk score, while the leakage-aware exploit classifier contributes a complementary probabilistic signal for ranking likely exploited vulnerabilities under label noise and class imbalance.

Calibration of predicted probabilities

Calibration measures whether predicted probabilities reflect the empirical frequency of the positive class. A model may rank cases well (high PR-AUC) yet still produce poorly

calibrated probabilities, which matters when probabilities are used as an operational decision signal. We therefore assess calibration on the held-out test set using (i) reliability diagrams (calibration curves) and (ii) the Brier score, a proper scoring rule that penalizes both misclassification and miscalibration.

Under the combined weak-supervision labeling strategy (positives: KEV-listed or EPSS above a high-risk threshold) and the leakage-aware feature protocol (excluding EPSS and KEV membership from classifier inputs), the resulting probabilities are no longer artificially near-deterministic. Table 8 shows Brier scores in the range 0.046–0.048 for tree-based models (XGBoost: 0.0460, Random Forest: 0.0462, HistGBM: 0.0477), while Logistic Regression is less well calibrated (Brier $\approx$ 0.058).

Figure 5 visualizes the calibration behavior across classifiers. XGBoost (a) and HistGBM (c) track the diagonal reasonably well in the bins where they place mass, indicating broadly reliable probabilities under this leakage-aware setup. Random Forest (b) shows larger deviations in the upper-probability region, reflecting instability due to the small number of high-confidence predictions under severe class imbalance. Logistic Regression (d) compresses predicted probabilities into a narrow band, producing limited separation and weaker calibration, consistent with its substantially lower PR-AUC. Overall, the reliability plots align with the Brier scores and indicate that, after leakage control, probability estimates are moderate and sensitive to the scarcity of positives, which is expected in real OT/ICS exploit prediction settings.

Precision–recall characteristics

Given the strong class imbalance in exploit labeling (only 46 positives in the 806-CVE test set under the combined weak-supervision strategy), the Precision–Recall (PR) curve is the most informative summary of classifier behavior. We report PR-AUC (Average

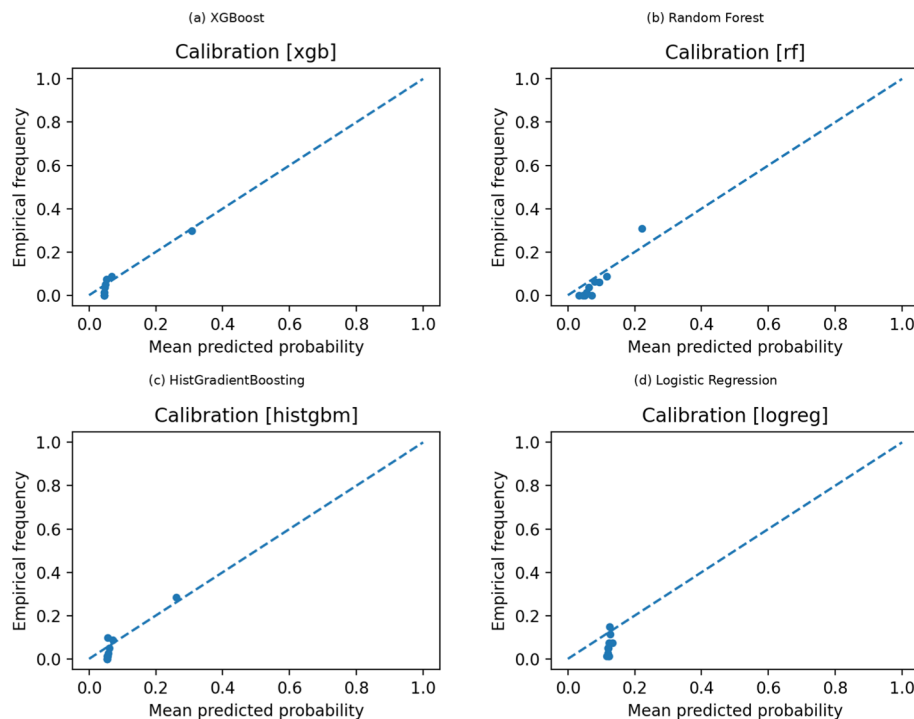


Fig. 5 Calibration curves (10-bin reliability diagrams) for the four exploit classifiers evaluated on the time-separated test set

Precision, AP) with 95% bootstrap confidence intervals, which emphasizes early ranking quality: high AP implies that truly exploited CVEs are concentrated near the top of the ranked list.

Figure 6 shows PR curves for all four classifiers evaluated under the leakage-aware feature protocol (i.e., EPSS and KEV membership are excluded from exploit-classifier inputs because they participate in label construction). Under this more realistic setup, performance drops from earlier near-ceiling values and better reflects the difficulty of exploit prediction in OT/ICS contexts. Random Forest (b) achieves the highest AP at 0.378 (95% CI: [0.285, 0.546]), followed by XGBoost (a) with AP = 0.331 (95% CI: [0.246, 0.496]) and HistGBM (c) with AP = 0.316 (95% CI: [0.241, 0.455]). Logistic Regression (d) performs substantially worse (AP = 0.091, 95% CI: [0.068, 0.129]), indicating limited ability to separate positives from negatives using a linear decision boundary on the available feature space. Overall, tree-based models provide meaningfully better ranking of weakly labeled exploited CVEs, while the widened confidence intervals highlight the statistical uncertainty introduced by the small number of positive test examples.

Regression accuracy and residual analysis

We evaluated four regressors on a time-based split (train: 3,224 CVEs; test: 806 CVEs) to predict the constructed continuous risk score. Overall, the regression task shows strong agreement with the analytic score formulation, with test-set R^2 ranging from 0.854 to 0.910 (Table 7). Ridge achieves the highest R^2 (0.910), while XGBoost attains the lowest MAE (0.0185), indicating slightly smaller average absolute deviations even though its explained variance is marginally lower.

To better understand error characteristics beyond summary metrics, we analyze the residuals on the test set (residual = true risk – predicted risk). Ideally, residuals should

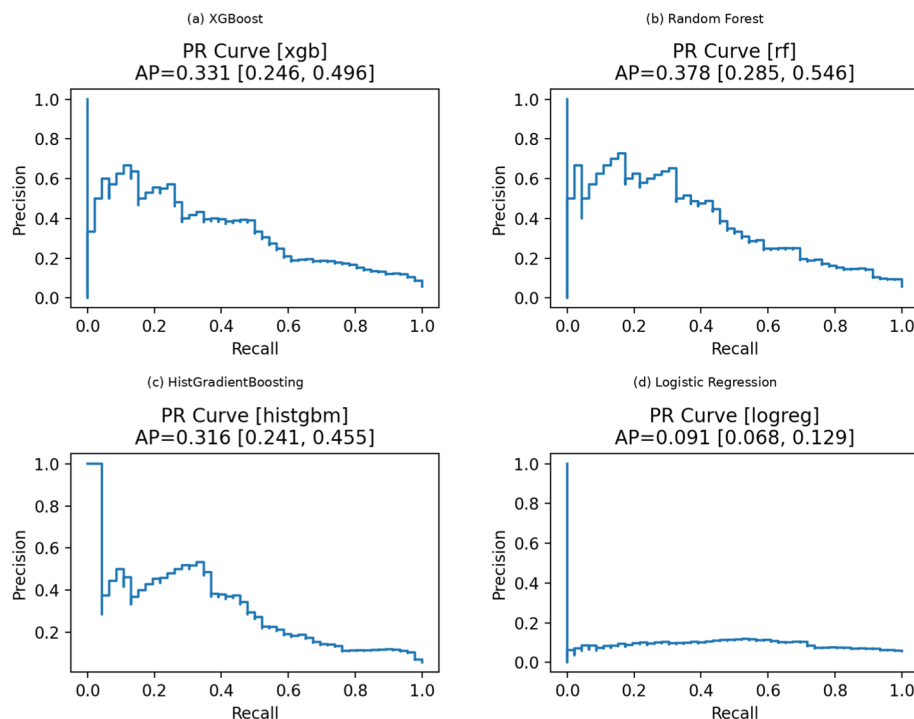


Fig. 6 PPrecision-Recall Curves for Each Classifier Model

be centered near zero with limited spread and no systematic skew. Figure 7 shows the residual histograms for all four regressors. All models exhibit residual mass concentrated around zero, indicating that most predictions closely match the constructed risk score. Ridge displays the tightest central concentration, consistent with its highest R^2 . XGBoost and HistGBM show similarly centered residuals with slightly wider tails, suggesting occasional larger deviations on specific CVEs. Random Forest exhibits the broadest spread and heavier tails, consistent with its lower R^2 and higher MAE.

Importantly, these regression results should be interpreted as fidelity to the constructed risk score (derived from severity, threat-intelligence, and contextual factors), rather than prediction of an external ground-truth “risk” outcome. In this sense, the regression stage provides a stable, interpretable estimate of the analytic risk formulation, which can then be combined with the separate exploit-likelihood signal for prioritization.

SHAP analysis

To make our prioritization model results more interpretable, we apply the SHAP technique to map the predicted analytic risk score to its original feature inputs. We compute the SHAP values for our ridge risk regressor risk model using a time-split and a random sample of 500 CVEs. We provide (i) feature importance through mean absolute values of the SHAP values and (ii) a summary (beeswarm) plot of feature values and their influence on predictions using the SHAP values. Since TF-IDF has thousands of sparse dimensions, we also aggregate feature contributions to feature families (e.g., TF-IDF text feature family and numeric and categorical feature indicators). The SHAP values for the ridge risk regressor are depicted in Figure 8. On a group level, it is clear that the TF-IDF text features have the largest influence, signifying that vulnerability descriptions contain CPPS-related context information that is not solely represented by scalar values of severity. On an individual scalar feature level, it is clear that CVSS and EPSS

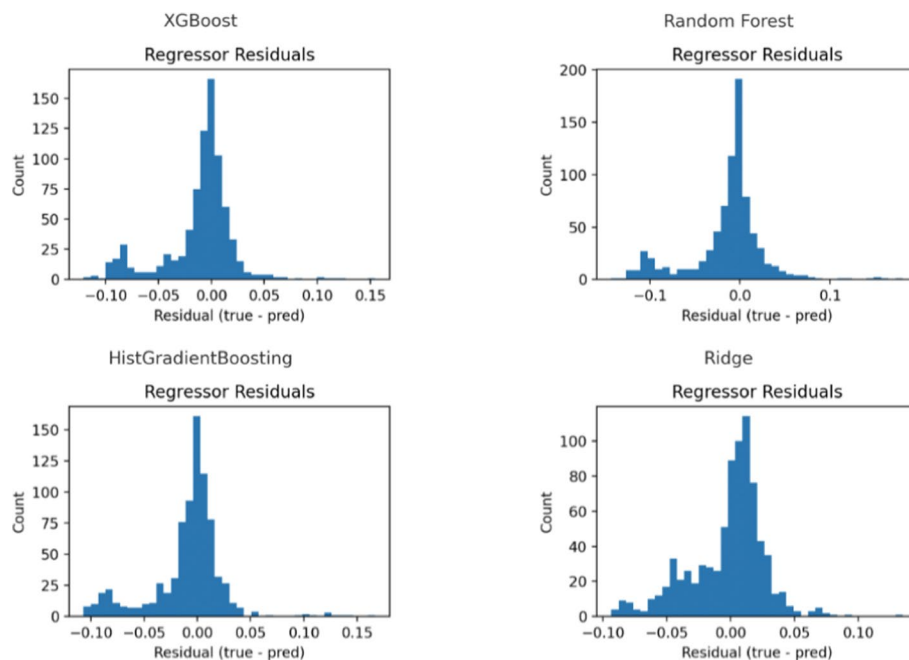


Fig. 7 Prediction Residual Distributions for Each Regression Model

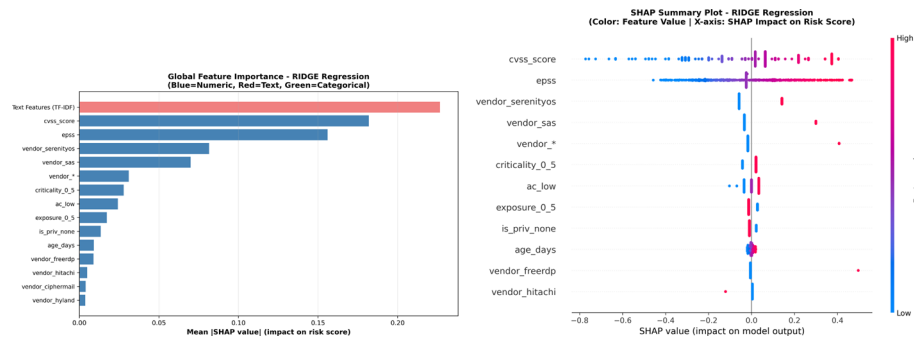


Fig. 8 SHAP explanations for the ridge risk regressor (time-based split)

Table 9 Baseline prioritization comparisons on the time-based holdout

Method	Workload for 100% KEV	KEV recall@100	KEV recall@200
CVSS-only (rank by CVSS)	363 (45.0%)	2/3 (66.7%)	3/3 (100%)
EPSS-only (rank by EPSS)	736 (91.3%)	2/3 (66.7%)	2/3 (66.7%)
Escalation rule (KEV $\vee$ EPSS ≥ 0.75)	46 (5.7%)	3/3 (100%)	3/3 (100%)
Proposed risk score (ours)	176 (21.8%)	2/3 (66.7%)	3/3 (100%)

have the largest absolute values, signifying that higher values of those features tend to increase predicted values of analytic risk. Vendor and CPPS context features have a secondary but not insignificant impact, signifying that proxy variables for asset structure and CPPS context can be beneficial to include, even if they are not standardized vulnerability metrics.

Baseline prioritization comparisons (Non-circular KEV-only evaluation)

To contextualize the proposed prioritization framework against simpler alternatives, we report baseline comparisons using a non-circular evaluation in which *CISA KEV membership in the held-out window* is treated as external confirmation (ground truth), while baseline ranking signals do not require KEV as an input. We compare: (i) CVSS-only ranking, (ii) EPSS-only ranking, (iii) an operational escalation rule that flags CVEs if they are KEV-listed or exceed a high EPSS threshold, and (iv) the proposed risk-based prioritization score. Table 9 summarizes two intuitive quantities: the review workload needed to capture all KEV CVEs in the test window (workload for 100% KEV recall) and KEV recall at fixed review budgets.

As shown, EPSS-only ranking can require reviewing most of the held-out CVEs to capture all KEV-confirmed items, whereas the proposed prioritization substantially reduces workload relative to CVSS-only and EPSS-only baselines while retaining full KEV capture within a smaller review budget. Because true confirmation of exploitation is deferred and incomplete, we present the above non-circular results as a lagged prospective check: test-window CVEs are evaluated against later KEV confirmation after an observation period.

Practical implications for CPPS operators

The proposed pipeline supports day-to-day vulnerability management in CPPS/OT settings where patching decisions are constrained by outage windows, safety, and certification requirements. In practice, the framework provides two complementary signals: (i) a stable, interpretable risk score that closely reproduces the analytic formulation on a

time-separated holdout set ($R^2 \approx 0.85\text{--}0.91$), and (ii) an exploit-likelihood probability that offers additional prioritization value but remains deliberately conservative under leakage-aware evaluation (PR-AUC $\approx 0.09\text{--}0.38$, depending on the classifier). This separation helps operators avoid over-trusting exploit prediction while still benefiting from a probabilistic indicator that can be used as a secondary triage cue.

Operationally, the output can be used to (1) focus scarce maintenance windows on a manageable subset of high-risk CVEs ranked by the risk score, while using the exploit probability as a tie-breaker among similarly scored items; (2) justify compensating controls (e.g., segmentation, access restrictions, protocol hardening, monitoring rules) when immediate patching is infeasible, especially for high-risk items on critical and exposed assets; and (3) provide product- and vendor-level rollups that highlight recurring high-priority issues to support asset planning and procurement discussions. Finally, model explanations (e.g., feature attributions for the risk regressor and classifier) can be presented as supporting evidence for why a CVE rises in the priority list, enabling analysts to communicate decisions to operations teams without treating the exploit prediction as a deterministic claim.

Limitations

This study has several limitations that affect both dataset construction and predictive evaluation. First, CPPS relevance is determined using vendor/product matching and keyword-based filtering, which can introduce selection bias (false positives/negatives and vendor skew). Second, exploit labels are inherently noisy and incomplete. Even under the combined weak-supervision strategy (KEV or high EPSS), labels reflect reporting and measurement availability rather than complete ground truth. To avoid optimistic bias, we explicitly exclude label-defining signals (KEV membership and EPSS) from the exploit-classifier feature set; however, the resulting performance (PR-AUC in the 0.09–0.38 range) indicates that exploit prediction remains difficult and should be interpreted as a ranking aid rather than a definitive forecast.

Third, context generalization remains limited. The criticality and exposure attributes are derived from generalized asset mappings and do not fully capture utility-specific topology, operational safeguards, or compensating controls that may reduce real-world exploitability. Fourth, temporal drift is expected: exploitation campaigns, vendor patch practices, and third-party scores evolve over time. We mitigate this partially using a time-based split and robustness checks across labeling assumptions, and we additionally report a non-circular KEV-only evaluation on the held-out window (Sec. 4.8); nonetheless, periodic retraining and validation on newly observed CVEs are necessary for sustained performance. Finally, our regression results primarily demonstrate fidelity to the constructed analytic risk score rather than prediction of an independent outcome; this is useful for consistent prioritization, but it does not replace incident-driven ground truth validation where such data become available.

Conclusion

In this paper, we presented a comprehensive approach to vulnerability risk assessment for CPPS that blends data aggregation, threat intelligence, and machine learning. Our work is motivated by the observation that while power systems are increasingly targeted by cyber threats, the community has lacked a structured dataset and analytical tools to

prioritize the multitude of ICS vulnerabilities disclosed each year. We addressed this gap by compiling an ICS-oriented dataset consisting of 4,030 CVEs in the years 2020–2025 and enriched the dataset using additional fields such as severity (CVSS), exploitation (EPSS and CISA KEV), as well as ICS-related fields like association and criticality. On this basis, we constructed a two-stage modeling pipeline to calculate a risk score for the CPPS and an exploitation likelihood. These efforts took into account the need to prioritize vulnerabilities, rather than just providing severity ratings. Our results show that combining threat intelligence with OT/ICS context yields a more practical prioritization signal, concentrating attention on a smaller set of high-priority vulnerabilities rather than treating all high-CVSS items as equally urgent. In practice, the dataset and scoring pipeline can support vulnerability management workflows such as patch scheduling, exception handling, and compensating controls when patching is not immediately feasible. This work also has important limitations. Exploit labels are sparse and may involve weak supervision, so exploit-likelihood performance is moderate under leakage-aware evaluation. Exploitation patterns and threat conditions can also shift over time, and CPPS relevance and asset importance inferred from public advisories may introduce bias or omissions in the analysis.

Future work will focus on improving the ground truth of the exploitation task by verifying labels using new sources of external evidence such as exploit code and vendor or ICS advisories, as well as checking for the robustness of assumptions about labeling. In addition, we propose enhancing the fidelity of the context by incorporating asset inventories specific to the utilities sector, topology-driven models of criticality and exposure, and additional threat intelligence sources. From the methodological side, the research will delve into both the temporal and the graph models of attacker activity and the relationships among the products and services, examining the generalizability of the results from the energy sector to other critical infrastructure industries.

Acknowledgements

This research was supported by the U.S. Department of Energy, Office of Environmental Management, Technology Operations Office Program.

Author contributions

F.K. conceived the study, designed the overall approach, led data collection and curation, implemented the risk scoring pipeline, performed the experiments, and wrote the initial draft of the manuscript. L.B. contributed to the cyber-physical power system problem formulation, supported data validation and result interpretation, and revised the manuscript for clarity and structure. A.M. contributed to the methodology design, feature engineering, and machine learning modeling, and assisted in writing and editing the methods and results sections. S.H. supervised the project, contributed to the study design and interpretation of findings, and critically revised the manuscript for important intellectual content. All authors read and approved the final manuscript.

Funding

U.S. Department of Energy, Office of Environmental Management, Technology Operations Office Program.

Data availability

The curated CPPS vulnerability dataset and all code used for data collection, enrichment, modelling, and analysis are available in the CASPER_01_Code repository on GitHub: https://github.com/firdous3679/CASPER_01_Code

Code availability

https://github.com/firdous3679/CASPER_01_Code

Declarations

Ethics approval and consent to participate

Not applicable

Consent for publication

Not applicable

Competing interests

The authors declare no competing interests.

Received: 30 November 2025 / Accepted: 28 January 2026

Published online: 06 February 2026

References

1. Abdul Rahim F, Ahmad NA, Magalingam P, Jamil N, Cob ZC, Salahudin L (2023) Cybersecurity vulnerabilities in smart grids with solar photovoltaic: a threat modelling and risk assessment approach. *Int J Sustain Constr Eng Technol* 14(3):210–220
2. AG S (2021) Apache log4j vulnerabilities (log4shell, cve-2021-44228, cve-2021-45046, dos, cve-2021-45105): Impact on industrial edge. <https://support.industry.siemens.com/cs/document/109806519>, entry date: 2021-12-22; Entry ID: 109806519
3. Alanazi M, Mahmood A, Chowdhury MJM (2025) Ics-ltu2022: a dataset for ics vulnerabilities. *Comput Secur* 148:104143
4. Balsam A, Nowak M, Walkowski M, Oko J, Sujecki S (2024) Comprehensive comparison between versions cvss v2.0, cvss v3.x and cvss v4.0 as vulnerability severity measures. In: 2024 24th International Conference on Transparent Optical Networks (ICTON). pp. 1–4. IEEE
5. Banik S, Rogers M, Mahajan SM, Emeghara CM, Banik T, Craven R (2024) Survey on vulnerability testing in the smart grid. *IEEE Access* 12:119146–119173. <https://doi.org/10.1109/ACCESS.2024.3449642>
6. Claroty Team82: Biannual ICS risk & vulnerability report: 2h 2021 (2022), <https://web-assets.claroty.com/resource-downloads/claroty-biannual-report-2h-2021.pdf>, fourth Biannual edition; covers vulnerabilities disclosed in 2H 2021
7. Cybersecurity and Infrastructure Security Agency: Ics advisories (Oct 2025), <https://www.cisa.gov/news-events/ics-advisories>, accessed on 2025-10-16
8. Cybersecurity and Infrastructure Security Agency: Known exploited vulnerabilities catalog (2025), <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>, continuously updated catalog of vulnerabilities known to be exploited in the wild
9. Dragos, Inc.: 2025 ot cybersecurity year in review (2025), <https://www.dragos.com/ot-cybersecurity-year-in-review>, 8th Annual Year in Review covering ICS/OT vulnerabilities, threats, and industry trends
10. Firdous K (2025) CASPER_01_Code: CPPS Vulnerabilities Dataset and Risk Scoring Pipeline. https://github.com/firdous3679/CASPER_01_Code, accessed: 2025-11-30
11. Forum of Incident Response and Security Teams (FIRST): Exploit prediction scoring system (epss) (2025), <https://www.first.org/epss/>, version 4 released March 17, 2025. Data-driven model estimating likelihood of software vulnerability exploitation in the wild
12. Gao X, Ali M, Sun W (2024) A risk assessment framework for cyber-physical security in distribution grids with grid-edge devices. *Energies* 17(7):1587. <https://doi.org/10.3390/en17071587>
13. Jacobs J, Romanosky S, Suciu O, Edwards B, Sarabi A (2023) Enhancing vulnerability prioritization: Data-driven exploit predictions with community-driven insights. In: 2023 IEEE European symposium on security and privacy workshops (euroS&PW). pp. 194–206. IEEE
14. Koscinski V, Nelson M, Okutan A, Falso R, Mirakhorli M (2025) Conflicting scores, confusing signals: An empirical study of vulnerability scoring systems. <https://arxiv.org/abs/2508.13644>, arXiv preprint, v1, CC BY 4.0
15. Mell P, Scarfone K, Romanosky S (2007) Common vulnerability scoring system. *IEEE Security & Privacy* 4(6):85–89
16. Mell P, Spring JM (2025) Likely exploited vulnerabilities, a proposed metric for vulnerability exploitation probability
17. Mitikiri SB, Babu KVSM, Srinivas VL, Chakraborty P, Pal M (2025) A comprehensive metric for resilience evaluation of power distribution systems under cyber attacks. arXiv preprint [arXiv:2501.12094](https://arxiv.org/abs/2501.12094)
18. Nikolaou N, Papadakis A, Psychogios K, Zahariadis T (2023) Vulnerability identification and assessment for critical infrastructures in the energy sector. *Electronics* 12(14):3185. <https://doi.org/10.3390/electronics12143185>
19. Paul B, Sarker A, Abhi SH, Das SK, Ali MF, Islam MM, Islam MR, Moyeen SI, Badal MFR, Ahamed MH, Sarker SK, Das P, Hasan MM, Saqib N (2024) Potential smart grid vulnerabilities to cyber attacks: current threats and existing mitigation strategies. *Heliyon* 10(19):e37980. <https://doi.org/10.1016/j.heliyon.2024.e37980>
20. Salehi A, Alimohammadi M, Khedmati M, Ghousi R (2025) Spatial-temporal dynamics in country-level sustainable energy performance using ensemble learning and analytic hierarchy process. *J Clean Prod* 508:145497. <https://doi.org/10.1016/j.jclepro.2025.145497>
21. Salehi A, Babaei A, Khedmati M (2025) Incident duration prediction through integration of uncertainty and risk factor evaluation: a San Francisco incidents case study. *PLoS One* 20(1):e0316289. <https://doi.org/10.1371/journal.pone.0316289>
22. Spring JM, Householder A, Hatleback E, Manion A, Oliver M, Sarvapalli V, Tyzenhaus L, Yarbrough C (2021) Prioritizing vulnerability response: A stakeholder-specific vulnerability categorization (version 2.0). Software Engineering Institute (SEI), Tech. Rep
23. Yan K, Liu X, Lu Y, Qin F (2023) A cyber-physical power system risk assessment model against cyberattacks. *IEEE Syst J* 17(2):2018–2028. <https://doi.org/10.1109/JSYST.2022.3215591>
24. Zhang K, Zhang Y, Fu J, Zheng J, Li W (2023) A vulnerability detection system for power internet of things equipment. 1658–1661. <https://doi.org/10.1109/ICBA56860.2023.10165526>

Publisher's Note

Springer Nature remains neutral with regard to jurisdictional claims in published maps and institutional affiliations.